VENDOR RISK ASSESSMENT MATRIX

AI Vendor Governance Suite | Evolve Edge

DOC-VRAM-2025

Companion to: Security Questionnaire (DOC-VASQ-2025)
Onboarding Checklist (DOC-VOC-2025)

Assessment Information

Vendor Name

Enter vendor company name

Vendor Website

https://

Vendor Type

Select type...

AI/ML Components Used

e.g. LLM API, Predictive Model, Chatbot

Assessment Date

mm/dd/yyyy

Next Review Date

mm/dd/yyyy

Assessor Name

Assessor Title

Department

e.g. IT Security, Risk & Compliance

Data Classification Level

Public (Low Impact)

Vendor Tier

Tier 1 - Critical

Assessment Scope

Describe the scope of services and AI usage being assessed...

Risk Scoring Methodology

How to Score: Risk is calculated as **Likelihood × Impact**. Select values from 1-5 for each criteria. The system will automatically calculate the Risk Score and assign a Risk Level.

Risk Levels

Score 1-5	LOW RISK
Score 6-12	MEDIUM RISK
Score 13-19	HIGH RISK
Score 20-25	CRITICAL RISK

Risk Heat Map

	1	2	3	4	5
5	5	10	15	20	25
4	4	8	12	16	20
3	3	6	9	12	15
2	2	4	6	8	10
1	1	2	3	4	5

X-Axis: Impact | Y-Axis: Likelihood

Security Risk Assessment

Evaluates technical controls, data protection measures, and cybersecurity posture of the vendor's AI systems.

#	Risk Criteria	Description	Likelihood	Impact	Risk Score	Level	Notes
1.1	**Data Encryption**	Data encrypted at rest (AES-256) & in transit (TLS 1.2+)	1		1	LOW	
1.2	**Access Control & MFA**	MFA, RBAC, least privilege principles enforced	1		1	LOW	
1.3	**Vulnerability Mgmt**	Regular pen testing, patch cycles, CVE remediation	1		1	LOW	
1.4	**Incident Response**	Breach notification ≤72hrs, IR plan tested annually	1		1	LOW	
1.5	**Network Security**	Firewalls, IDS/IPS, segmentation, zero-trust	1		1	LOW	
1.6	**AI/ML Model Security**	Model versioning, adversarial/injection protection	1		1	LOW	
1.7	**Supply Chain Security**	Vendor vetting, SBOM, sub-processor controls	1		1	LOW	
1.8	**Endpoint Security**	Device mgmt, EDR deployment, BYOD policy	1		1	LOW	

ITEMS ASSESSED	AVG RISK SCORE	RISK LEVEL
8	1	LOW

Compliance Risk Assessment

Assesses regulatory adherence, certification status, and legal compliance across applicable AI governance frameworks.

#	Risk Criteria	Description	Likelihood	Impact	Risk Score	Level	Notes
2.1	**GDPR Compliance**	Data subject rights, lawful basis, DPA in place	1		1	LOW	
2.2	**HIPAA Compliance**	PHI controls, BAA signed, minimum necessary rule	1		1	LOW	
2.3	**SOC 2 Type II**	Current report, trust criteria coverage, bridge letter	1		1	LOW	
2.4	**PCI DSS**	Cardholder data protection, quarterly scans	1		1	LOW	
2.5	**ISO 27001**	Active cert, AI systems in audit scope	1		1	LOW	
2.6	**NIST AI RMF**	AI risk mgmt framework alignment, model cards	1		1	LOW	

#	Risk Criteria	Description	Likelihood	Impact	Risk Score	Level	Notes
2.7	**Data Localization**	Cross-border transfers, SCCs, residency controls	1		1	LOW	
2.8	**AI Ethics & Bias**	Bias testing, fairness metrics, ethics committee	1		1	LOW	

ITEMS ASSESSED	AVG RISK SCORE	RISK LEVEL
8	1	LOW

Operational Risk Assessment

Reviews business continuity, financial health, service reliability, and long-term viability of the vendor relationship.

#	Risk Criteria	Description	Likelihood	Impact	Risk Score	Level	Notes
3.1	**Business Continuity**	BCP/DR documented & tested, RTO/RPO defined	1		1	LOW	
3.2	**SLA & Uptime**	Uptime ≥99.9%, SLA penalties defined	1		1	LOW	
3.3	**Financial Stability**	Credit rating, funding status, profitability	1		1	LOW	
3.4	**Key Person Risk**	Bus factor >1, succession plan, low turnover	1		1	LOW	
3.5	**Vendor Lock-in**	Data portability, APIs, exit clauses	1		1	LOW	
3.6	**AI Transparency**	Explainability, audit trails, no black-box risk	1		1	LOW	

#	Risk Criteria	Description	Likelihood	Impact	Risk Score	Level	Notes
3.7	**Data Exit Strategy**	Deletion timelines, export formats, transition SLA	1		1	LOW	
3.8	**Change Management**	Notice of changes, rollback, advisory board	1		1	LOW	

ITEMS ASSESSED	AVG RISK SCORE	RISK LEVEL
8	1	LOW

Risk Summary Dashboard

Security Risk Score	Compliance Risk Score	Operational Risk Score
1	1	1
LOW	LOW	LOW

OVERALL COMPOSITE RISK SCORE

1

LOW RISK

Weighted: Security (40%) + Compliance (35%) + Operational (25%)

Identified Risk Register

ID	Risk Description	Category	Mitigation Action	Status
R-C	Description...	Secu	Action...	Ope
R-C		Secu		Ope

ID	Risk Description	Category	Mitigation Action	Status
R-C		Secu		Ope

Remediation Plan

Immediate Actions (0-30 Days)

- Critical patch application
- Enable MFA on root accounts...

Short-Term (30-90 Days)

- Update privacy policy
- Conduct pen test...

Long-Term (90+ Days)

- ISO 27001 Certification
- Implement automated compliance monitoring...

✍️ Final Assessment & Sign-Off

Final Determination

✅ **APPROVED**
Vendor meets all risk thresholds

⚠️ **CONDITIONALLY APPROVED**
Minor gaps, remediation in 30 days

🔴 **HIGH RISK / EXCEPTION**
Executive approval required

❌ **REJECTED**
Critical risk, do not proceed

Conditions / Comments

Enter any specific conditions of approval or reasons for rejection...

Risk Assessor

Name

Title

Signature

Date: mm/dd/yyyy

Authorizing Manager

Name

Title

Signature

Date: mm/dd/yyyy

Evolve Edge | AI Vendor Governance Suite

Document ID: DOC-VRAM-2025 | Version 1.0 | Confidential

© 2025 Evolve Edge. All rights reserved.